

Firewall Security[1]

HARDNESS : 8/10



University of Tehran
School of Electrical and Computer Engineering

دانشگاه تهران
دانشکده‌ی مهندسی برق و کامپیوتر

Computer Network Lab
آزمایشگاه شبکه‌های کامپیوتری

Professor:
Dr. Ahmad Khonsari
دکتر احمد خونساری
a_khonsari@ut.ac.ir

Amir Haji Ali Khamseh'i
امیر حاجی‌علی‌خمسه‌ء
khamse@ut.ac.ir

Reza Sharifnia
رضا شریف نیا
Reza.sharifnia@ut.ac.ir

Muhammad Borhani
محمد برهانی
borhani.m@ut.ac.ir

AmirAhmad Khordadi
امیراحمد خردادی
a.a.khordadi@ut.ac.ir

Sina Kashipazha
سینا کاشی‌پزها
sina_kashipazha@ut.ac.ir

Hadi Safari
هادی صفری
hadi.safari@ut.ac.ir

Ali Abedini
علی عابدینی
aliabedini2001@ut.ac.ir

November 1, 2026

۱۰ آبان ۱۴۰۵

[1]S. Panwar, S. Mao, J.-dong Ryoo, and Y. Li, "Network management and security," in TCP/IP Essentials: A Lab-

Objectives

- Learn how to setup a fortigate firewall through its graphical user interface (GUI).
- Implement firewall rules to secure network segments and mitigate common attacks.
- Simulate a **Distributed Denial of Service (DDoS)** attack, specifically a **SYN Flooding attack**, to understand its impact on network services.
- Configure the firewall to effectively mitigate the SYN Flooding attack by dropping irrelevant or malicious SYN packets.
- Verify that the firewall successfully drops irrelevant IP packets during a DDoS attack.

Agenda

This lab report outlines the step-by-step process for setting up a Fortigate firewall, simulating a DDoS attack, and implementing mitigation strategies. Students will follow these instructions:

1. **Fortigate Firewall Deployment**: Deploy the Fortigate firewall within the PNETLAB environment, connecting it to relevant network segments as shown in Figure 1.
2. **Initial Firewall GUI Configuration**: Access the Fortigate firewall's web-based user interface and perform initial setup, including:
   - Setting up administrative credentials.
   - Configuring WAN, LAN, and DMZ interfaces with appropriate IP addresses and enabling necessary administrative access (HTTP, HTTPS, Ping, SSH).
   - Configuring DNS servers and a default static route for internet connectivity.
   - Enabling DHCP services on internal interfaces (LAN, DMZ) for client machines.
3. **Firewall Policy Implementation**: Create initial firewall policies to allow necessary traffic flow between network segments and to the internet.
4. **DDoS Attack Simulation (SYN Flooding)**:
   - Prepare a Kali Linux machine to act as an attacker.
   - Execute a **SYN Flooding attack** against a target server using tools like `hping3`.
   - Observe the impact of the attack using network monitoring tools like `wireshark` and by attempting to access the target service.
5. **DDoS Mitigation Configuration**: Implement specific firewall rules on the Fortigate to detect and mitigate the SYN Flooding attack. This includes configuring policies to drop or rate-limit suspicious SYN packets originating from unknown or malicious sources.
6. **Verification of Mitigation**: Re-run the SYN Flooding attack and verify that the Fortigate firewall successfully drops irrelevant or malicious SYN packets, protecting the target server and ensuring service availability. This can be observed through firewall logs and continued accessibility of the protected service.

Based Approach, Cambridge: Cambridge University Press, 2004, pp. 187–213.

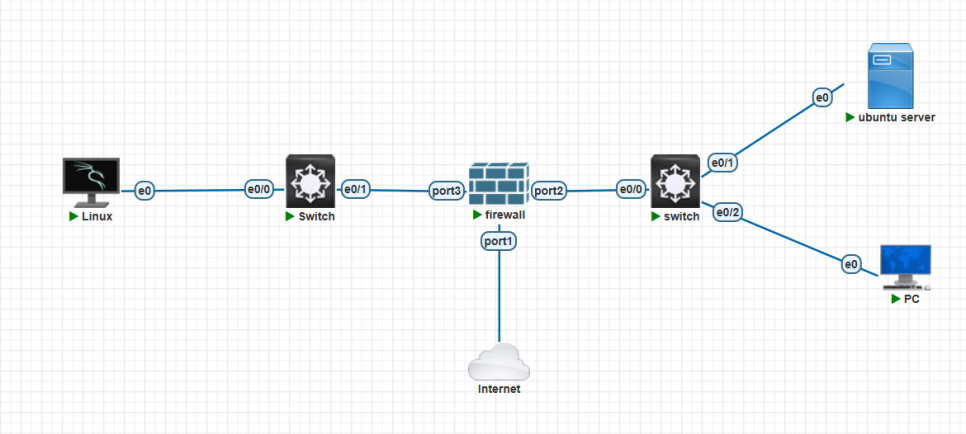


Figure 1: Topology

Firewall Setup

For this laboratory manual, the network topology is given in Figure 1 .

Fortigate Firewall GUI Configuration

This section guides you through the initial setup and configuration of the Fortigate firewall using its web-based graphical user interface (GUI).

1. **Initial Access and Password Setup**:
   - Start the Fortigate firewall in your PNETLAB environment.
   - Access its console. The default username is `admin` with no initial password. You will be prompted to set a new password. For example, use `123`.

     Fortigate Console

     ```
     admin
     <Enter> (no password initially)
     New password: 123
     Confirm password: 123
     ```

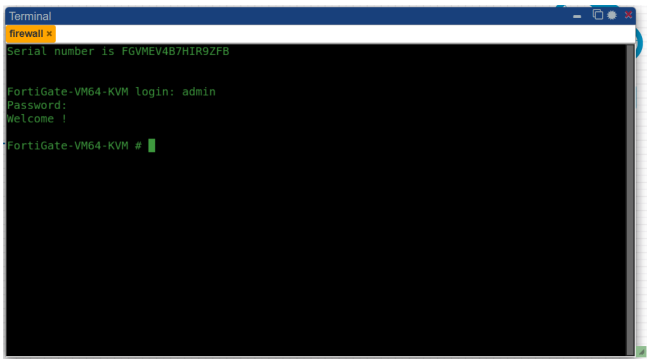


Figure 2: Initial Access and Password Setup

2. **Enable HTTP for GUI Access (if needed)**:

- By default, HTTPS might not be accessible or licensed on a basic Fortigate setup. To access the GUI, you might need to explicitly enable HTTP on the management interface (typically port1).
  Fortigate Console

```
config system interface
edit port1
set allowaccess http https ping ssh
end
```

- Identify the IP address assigned to port1 (e.g., `show system interface port1`).

3. **Access GUI and Configure Interfaces**:
4. Open a web browser on a client machine (e.g., *gui* or *PC* in Figure 1) that can reach the Fortigate's management IP. Navigate to `http://<Fortigate port1 IP>`.
5. Log in with username `admin` and the password you set.

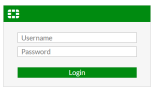


Figure 3: Login Page

6. **Access GUI and Configure Interfaces**:
   - Open a web browser on a machine that can reach the Fortigate's management IP. Navigate to the IP of the WAN interface (e.g., `http://172.18.128.139`).
   - Log in with username `admin` and the password you set.

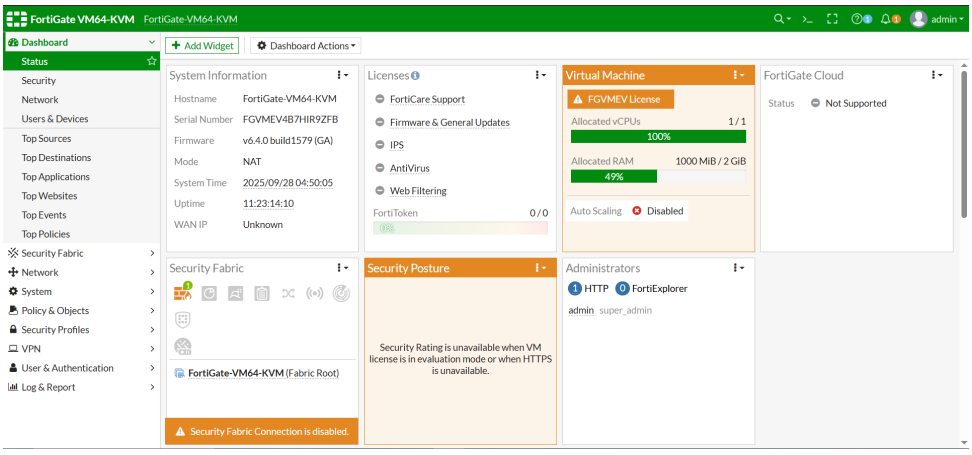


Figure 4: Firewall Dashboard

- Navigate to **Network** → **Interfaces**. Configure the interfaces to match the provided screenshot.
  Network → Interfaces

Name	IP/Netmask	Administrative Access
WAN (port1)	172.18.128.139/27	PING, HTTPS, SSH, HTTP...
DMZ (port2)	192.168.2.254/24	PING, HTTPS, SSH, HTTP...
LAN (port3)	192.168.3.1/24	PING

- **Configure WAN (port1)**:
  - Edit `port1`. Assign it the alias `WAN`.
  - Set its IP address to `172.18.128.139/27`.
  - Allow `PING`, `HTTPS`, `SSH`, and `HTTP` for administrative access. Click `OK`.
- **Configure DMZ (port2)**:
  - Edit `port2`. Assign it the alias `DMZ`.
  - Set its IP address to `192.168.2.254/24`.
  - Allow `PING`, `HTTPS`, `SSH`, and `HTTP`.
  - Enable the **DHCP Server** and set the range from `192.168.2.1` to `192.168.2.253`. Click `OK`.
- **Configure LAN (port3)**:
  - Edit `port3`. Assign it the alias `LAN`.
  - Set its IP address to `192.168.3.1/24`.
  - Allow `PING` for administrative access.
  - Enable the **DHCP Server** and set the range from `192.168.3.2` to `192.168.3.254`. Click `OK`.

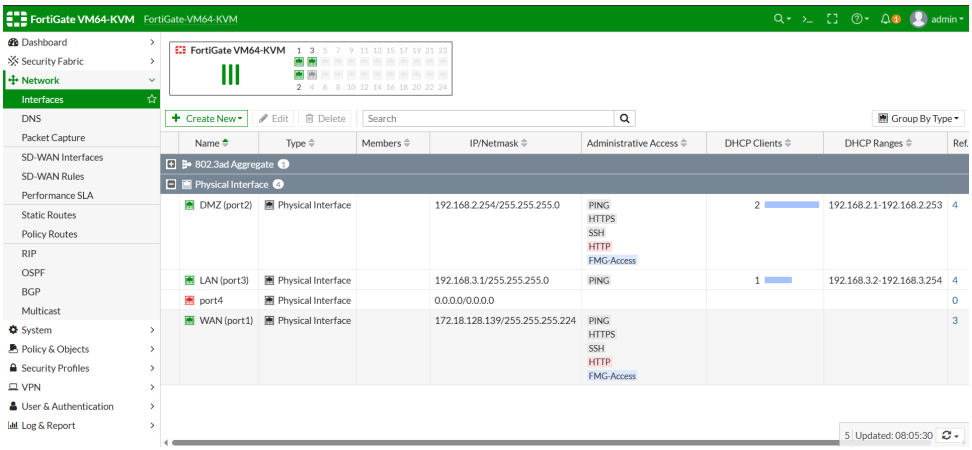


Figure 5: Network -> Interfaces

7. **Configure DNS and Static Route**:
   - Navigate to **Network** → **DNS**.
   - Configure the DNS Servers as specified in the screenshot.

     Network → DNS

     ```
     Primary DNS Server:   8.8.8.8
     Secondary DNS Server: 208.91.112.52
     ```

   - Click `Apply`.

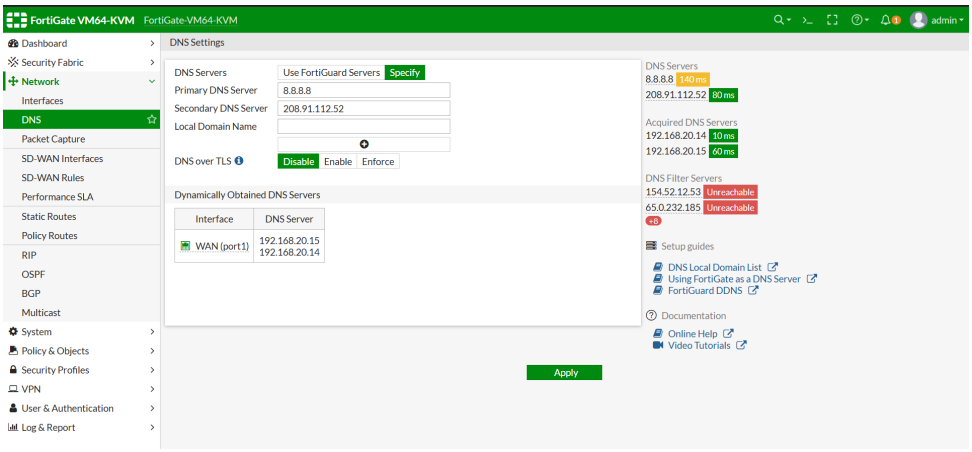


Figure 6: Network -> DNS

- Navigate to **Network** → **Static Routes**.
- Create a new default route: Destination: `0.0.0.0/0`, Gateway: Your WAN gateway, Interface: `WAN (port1)`. Click `OK`.

8. **Create Address Objects and Firewall Policies**:

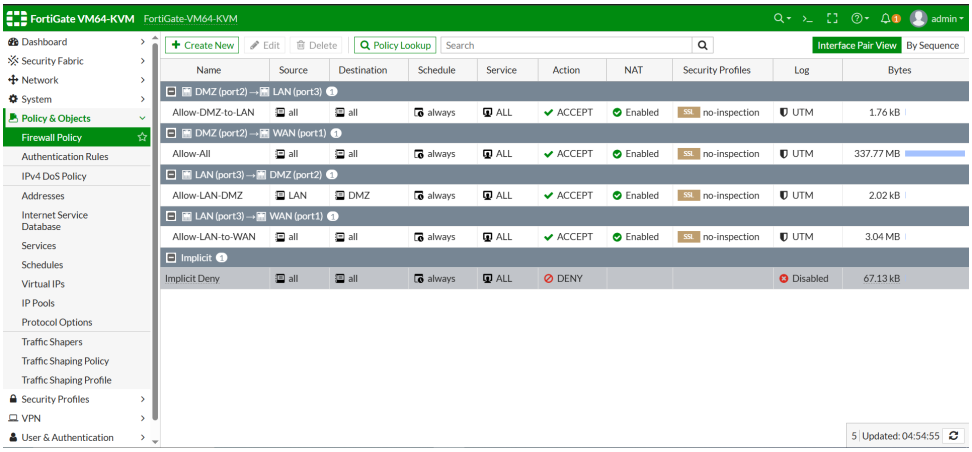


Figure 7: Policy & Objects

9. **Create Custom Address Objects (Source/Destination)**: To create specific policies, first define address objects for your networks.
   - Navigate to **Policy & Objects** → **Addresses**.
   - Click **Create New** → **Address**.
   - Create an object for the LAN subnet:
     - **Name**: `LAN`
     - **Type**: `Subnet`
     - **Subnet**: `192.168.3.0/24`
     - **Interface**: `LAN (port3)`
     - Click `OK`.
   - Create another object for the DMZ subnet:
     - **Name**: `DMZ`
     - **Type**: `Subnet`
     - **Subnet**: `192.168.2.0/24`
     - **Interface**: `DMZ (port2)`

- Click `OK`.

10. **Create Firewall Policies**: Navigate to **Policy & Objects** → **Firewall Policy**. Create new policies to match the rules shown in the screenshot.

- **Rule 1 (Allow-LAN-to-WAN)** as shown in Figure 8:
  - Click **Create New**.
  - **Name**: `Allow-LAN-to-WAN`
  - **Incoming Interface**: `LAN (port3)`
  - **Outgoing Interface**: `WAN (port1)`
  - **Source**: `all`
  - **Destination**: `all`
  - **Service**: `ALL`
  - **Action**: `ACCEPT`
  - **NAT**: `Enabled`
  - Click `OK`.

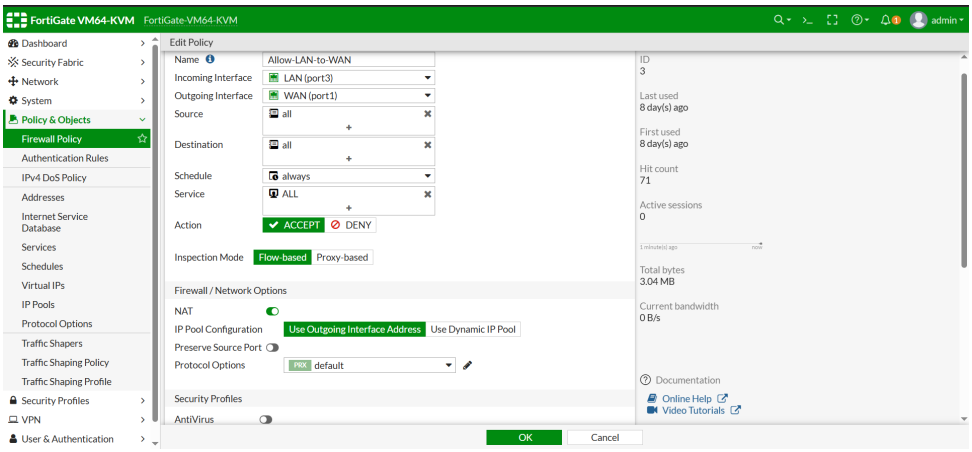


Figure 8: Rule 1 (Allow-LAN-to-WAN)

- **Rule 2 (Allow-LAN-DMZ)** as shown in Figure 9:
  - Click **Create New**.
  - **Name**: `Allow-LAN-DMZ`
  - **Incoming Interface**: `LAN (port3)`
  - **Outgoing Interface**: `DMZ (port2)`
  - **Source**: Select the `LAN` address object you created.
  - **Destination**: Select the `DMZ` address object you created.
  - **Service**: `ALL`
  - **Action**: `ACCEPT`
  - **NAT**: `Enabled` (as per screenshot)
  - Click `OK`.

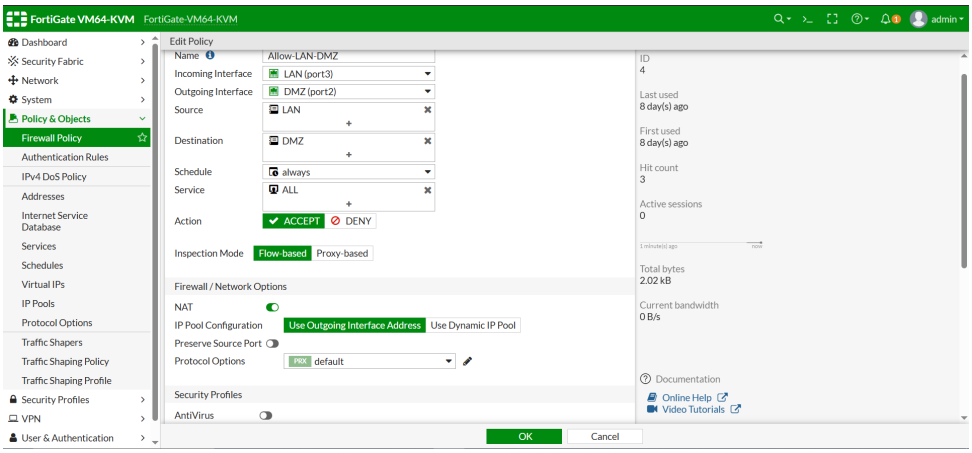


Figure 9: Rule 2 (Allow-LAN-DMZ)

- Create two more rules, **Allow-DMZ-to-WAN** and **Allow-DMZ-to-LAN**, following the logic from the screenshot to allow traffic from the DMZ to the Internet and the internal LAN respectively. As shown in figures 10 and 11.

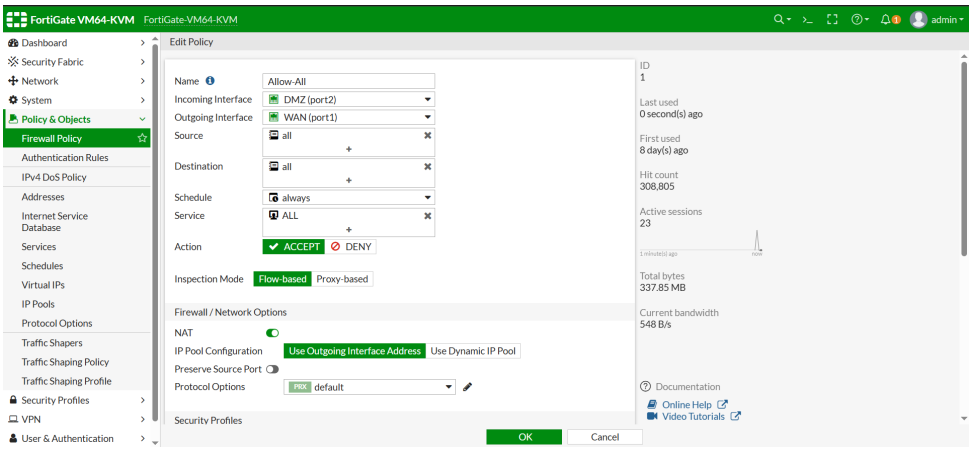


Figure 10: Allow-DMZ-to-WAN or Allow-All RULE

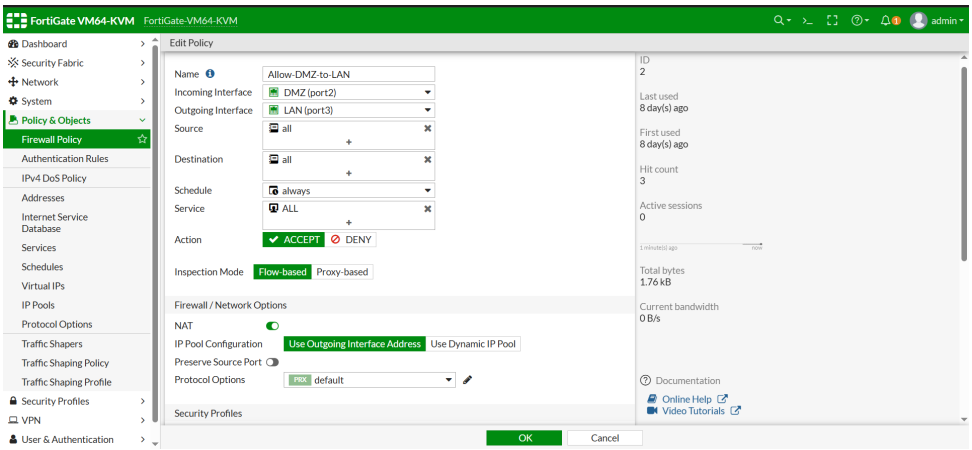


Figure 11: Allow-DMZ-to-LAN

11. **Configure Static Route and DNS**:

- Navigate to **Network** → **Static Routes**.

- Create a new static route as shown in Figure 12:
  - **Destination**: `0.0.0.0/0` (default route).
  - **Gateway**: The gateway IP of your WAN segment (e.g., `192.168.114.2`).
  - **Interface**: `port1` (or your designated WAN interface).
  - Click `OK`.

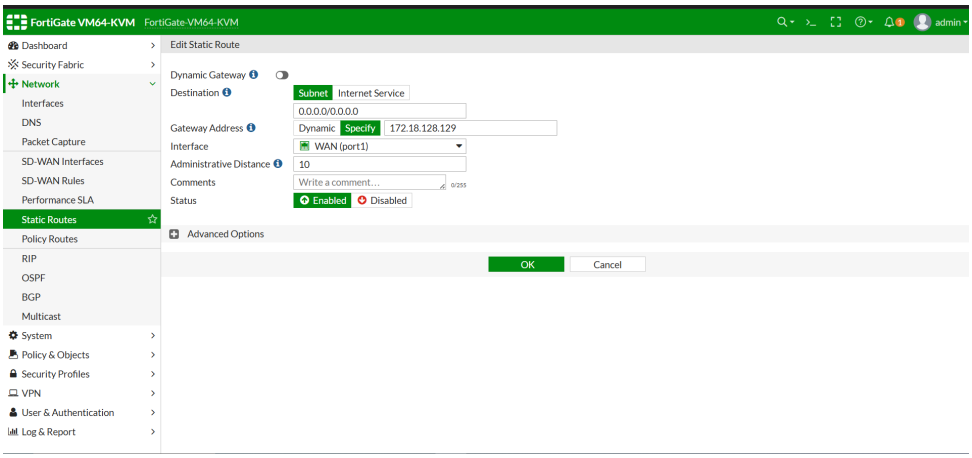


Figure 12: **Network → Static Routes**

- Navigate to **System → DNS**. Configure primary and secondary DNS servers (e.g., `8.8.8.8` and `8.8.4.4`).(Figure 6)

12. **Create Firewall Policies**:
    - Navigate to **Policy & Objects → Firewall Policy**.
    - Create policies to allow traffic as per your lab requirements. Examples:
      - **Allow LAN to WAN**: Incoming Interface: `port2` (LAN), Outgoing Interface: `port1` (WAN), Source: `all`, Destination: `all`, Service: `all`. Enable NAT.
      - **Allow DMZ to WAN**: Incoming Interface: `port3` (DMZ), Outgoing Interface: `port1` (WAN), Source: `all`, Destination: `all`, Service: `all`. Enable NAT.
      - **Allow LAN to DMZ**: Incoming Interface: `port2` (LAN), Outgoing Interface: `port3` (DMZ), Source: `LAN subnet`, Destination: `DMZ subnet`, Service: `all`. Disable NAT.
      - **Allow DMZ to LAN**: Incoming Interface: `port3` (DMZ), Outgoing Interface: `port2` (LAN), Source: `DMZ subnet`, Destination: `LAN subnet`, Service: `all`. Disable NAT.
    - Ensure all policies are enabled.

DDOS Attack and Mitigation

SYN Flooding Attack

A SYN Flooding attack is a type of **Denial of Service (DoS)** or **Distributed Denial of Service (DDoS)** attack that exploits the **TCP three-way handshake**. The attacker sends a large number of **SYN** (synchronize) requests to a target server, but does not complete the handshake by sending the final **ACK** (acknowledgment). This leaves the server with many "half-open" connections, consuming its resources and making it unable to respond to legitimate clients.

Performing the SYN Flooding Attack

To demonstrate a SYN Flooding attack, you will use a Kali Linux machine (e.g., *Linux* in Figure 1) as the attacker and a server (e.g., *ubuntu server*) as the target.

1. **Identify Target IP**: Determine the IP address of your target server (e.g., `192.168.2.100` if it's in the DMZ segment).
2. **Start Wireshark on Target Segment**: Execute `wireshark` on the segment connected to the target server (e.g., the switch connected to the *ubuntu server*) to capture traffic.
3. **Execute "hping3" Command**: On your Kali Linux attacker machine, open a terminal and execute the following command to initiate a SYN flood:

   Attacker Console (Kali Linux)

   ```
   hping3 -c 15000 -d 120 -w 64 -p 80 --flood --rand-source <Target_Server_IP>
   ```

   - `-c 15000`: Sends 15,000 packets. Adjust for desired intensity.
   - `-d 120`: Sets data size to 120 bytes.
   - `-w 64`: Sets TCP window size to 64.
   - `-p 80`: Targets port 80 (HTTP) on the server.
   - `-flood`: Sends packets as fast as possible, without waiting for replies.
   - `-rand-source`: Uses random source IP addresses, making it harder to block.
   - `<Target Server IP>`: Replace with the actual IP address of your target server.
4. **Observe Impact**: While the attack is running, try to access a service on the target server (e.g., a web page) from another client machine. You should observe significant slowdowns or complete unresponsiveness. In Wireshark, you will see a large number of incoming SYN packets without corresponding ACK packets.

DDoS Mitigation using Fortigate Firewall

To mitigate the SYN Flooding attack, you will configure specific firewall policies on the Fortigate firewall. This involves identifying and blocking or rate-limiting traffic that exhibits characteristics of a SYN flood.

Configuring Mitigation Rules

1. **Access Fortigate GUI**: Log back into the Fortigate firewall's web GUI.
2. **Navigate to Firewall Policies**: Go to **Policy & Objects** → **Firewall Policy**.
3. **Create a New Mitigation Policy**:
   - Click **Create New**.
   - **Name**: `DDoS SYN Flood Mitigation`
   - **Incoming Interface**: The interface connected to the segment where the attack is originating (e.g., `port1` for external attacks, or `port3` if the attacker is in the DMZ).
   - **Outgoing Interface**: The interface connected to the target server (e.g., `port3` for a server in DMZ).
   - **Source**: Define an address object for "External Networks" or "Any" initially. For more refined rules, you could create a source address group of "suspicious IPs" if known.
   - **Destination**: Define an address object for your target server.
   - **Service**: `HTTP` (for port 80), or the specific service being targeted.
   - **Action**: Set to `DENY` or `REJECT`.
   - **Enable Logging**: Ensure logging is enabled to verify the rule's effectiveness.
   - **Consider Rate Limiting (Optional but Recommended for SYN Floods)**: While the prompt asks to *drop* irrelevant IPs, a more sophisticated mitigation for SYN floods often involves **rate-limiting**. Fortigate firewalls typically offer **DoS Policies** or options within standard policies to limit the rate of SYN packets from a single source or to a destination. Explore these options if available in your Fortigate version. For this lab, a simple 'DENY' policy based on source/destination for suspicious traffic can demonstrate the dropping of irrelevant IPs.
   - Position this rule higher in the policy list so it's evaluated before general 'ALLOW' policies.
4. **Apply Changes**: Save and apply the new firewall policy.

Verification of Successful Mitigation

After implementing the DDoS mitigation policy:

1. **Re-run the SYN Flooding Attack**: From your Kali Linux machine, execute the `hping3` command again.
2. **Check Firewall Logs**: On the Fortigate GUI, navigate to **Log & Report** → **Forward Traffic** (or similar, depending on Fortigate version) and filter for traffic matching your mitigation policy. You should see logs indicating that packets are being **denied/dropped** by the `DDoS SYN Flood Mitigation` policy.
3. **Test Server Responsiveness**: From a legitimate client machine, attempt to access the target server's service. The server should now be responsive, indicating that the firewall is successfully dropping the malicious SYN packets and protecting the service from the attack.
4. **Wireshark Observation**: Observe the traffic on the target server's segment using `wireshark`. You should see fewer or no SYN packets reaching the server, or at least a significant reduction, as the firewall is intercepting them.

The successful observation of dropped packets in the firewall logs and the restoration of server responsiveness confirm that the firewall setup effectively mitigates the DDoS attack by dropping irrelevant IPs.